

Guía metodológica de la Encuesta OWASP 2025 – España

Versión 1.0 – Propuesta para pilotos sectoriales y uso institucional

1. Objetivos de la encuesta

La encuesta OWASP 2025 – España tiene como finalidad principal medir, de forma cuantitativa y comparable, el grado de adopción y aplicación de:

- Los marcos OWASP Top 10:2025, OWASP SAMM y OWASP ASVS 5.0.
- La Metodología de Rating de Riesgo de OWASP en la práctica de gestión de riesgos.
- Prácticas de cultura, formación y gobernanza relacionadas con ciberseguridad.

Y, al mismo tiempo, evaluar el alineamiento de estas prácticas con las obligaciones y el espíritu de:

- La Directiva NIS2 (gestión de riesgos, medidas técnicas y organizativas, gobernanza y notificación de incidentes).
- El Esquema Nacional de Seguridad (ENS) en sus distintas categorías.

El objetivo último es disponer de un **Índice Global de Madurez (IGM)** que permita:

- Comparar organizaciones y sectores.
- Identificar brechas y prioridades de mejora.
- Alimentar políticas públicas y estrategias corporativas con datos, no solo con buenas intenciones.

2. Población objetivo y muestreo

2.1. Población objetivo

La población objetivo de la encuesta está formada por organizaciones:

- Sujetos directos de NIS2 (esenciales e importantes),
- Sujetos al ENS (por su relación con el sector público),
- Proveedores TIC que prestan servicios relevantes a las anteriores.

2.2. Unidad de análisis

La unidad de análisis es la **organización** (entidad legal) o, en su caso, una unidad de negocio suficientemente autónoma con:

- Gobierno de TI y ciberseguridad diferenciados.
- Ambito claro de sistemas, aplicaciones y procesos.

2.3. Selección y muestreo

Se recomienda una combinación de:

- Muestreo intencional de organizaciones críticas (por tamaño, sector, impacto en servicios esenciales), y
- Muestreo estratificado por sector y tamaño para obtener representatividad.

Ejemplo de estratos:

- Sector (energía, transporte, salud, banca, administraciones públicas, TIC, etc.).
- Tamaño (PYME, mediana, gran organización).
- Relación con ENS (no aplica, ENS básico, ENS medio, ENS alto).

3. Diseño de la encuesta y bloques temáticos

La encuesta se organiza en bloques que reflejan tanto los marcos OWASP como las exigencias de NIS2/ENS:

1. Perfil de la organización.
2. Gobernanza, riesgo y métricas (visión general).
3. OWASP Top 10:2025 (exposición y tratamiento).
4. OWASP SAMM (madurez de programa).
5. OWASP ASVS 5.0 (verificación técnica).
6. Metodología OWASP de Rating de Riesgo.
7. Cultura, formación y capacidades humanas.
8. Cadena de suministro y terceros.
9. Operaciones, incidentes y continuidad.
10. Resultados globales y compromiso (opcional, en versiones extendidas).

Cada bloque incluye preguntas cerradas con opciones diseñadas para:

- Minimizar sesgos de deseabilidad social (evitar que todas las respuestas “correctas” suenen obvias).
- Permitir una codificación numérica clara (para índices y KPIs).
- Introducir, con moderación, un tono irónico y narrativo que invite a la reflexión honesta.

4. Escalas de respuesta y codificación

4.1. Tipos de preguntas

Se utilizan principalmente:

- Elección única categórica (por ejemplo, 0–25 %, 26–50 %, etc.).
- Múltiple respuesta (varias opciones que pueden aplicar simultáneamente).
- Escalas ordinales (por ejemplo, “No, parcial, sí”).

En las versiones avanzadas se puede añadir:

- Escalas tipo Likert de 1 a 5 (totalmente en desacuerdo – totalmente de acuerdo) para evaluar percepciones.

4.2. Codificación sugerida

Ejemplo para porcentajes:

- 0–25 % → 1.
- 26–50 % → 2.
- 51–75 % → 3.
- 76–100 % → 4.

Ejemplo para madurez SAMM (niveles 0–3):

- Nivel 0 → 0.
- Nivel 1 → 1.
- Nivel 2 → 2.
- Nivel 3 → 3.

Ejemplo para conocimiento/uso:

- No se conoce → 0.
- Se conoce pero no se aplica → 1.
- Se aplica parcialmente → 2.
- Se aplica sistemáticamente → 3.

La guía técnica (plantilla Excel) detallará la codificación exacta para cada pregunta.

5. Cálculo del Índice Global de Madurez (IGM)

5.1. Estructura del IGM

Se propone que el IGM se componga de cuatro subíndices principales:

11.

IGM-Exposición OWASP (Top 10)

Mide la capacidad de la organización para conocer, detectar y remediar vulnerabilidades alineadas con el Top 10.

12.

IGM-Madurez de Programa (SAMM)

Evalúa la madurez de procesos de seguridad de software según prácticas clave de SAMM (especialmente Gobernanza, Verificación y Operaciones).

13.

IGM-Aseguramiento Técnico (ASVS)

Refleja el nivel de verificación de aplicaciones según ASVS (niveles, cobertura de requisitos y pruebas).

14.

IGM-Gobernanza y Cultura

Mide la integración de la ciberseguridad en la alta dirección, el uso de métricas, la formación, la cultura de reporte y la gestión de la cadena de suministro.

IGM-Exposición OWASP (Top 10)

Mide la capacidad de la organización para conocer, detectar y remediar vulnerabilidades alineadas con el Top 10.

IGM-Madurez de Programa (SAMM)

Evalúa la madurez de procesos de seguridad de software según prácticas clave de SAMM (especialmente Gobernanza, Verificación y Operaciones).

IGM-Aseguramiento Técnico (ASVS)

Refleja el nivel de verificación de aplicaciones según ASVS (niveles, cobertura de requisitos y pruebas).

IGM-Gobernanza y Cultura

Mide la integración de la ciberseguridad en la alta dirección, el uso de métricas, la formación, la cultura de reporte y la gestión de la cadena de suministro.

Cada subíndice se calcula en una escala de 0 a 100 y el IGM global se obtiene como media ponderada.

5.2. Selección de variables por subíndice

Ejemplo de asignación (a ajustar en función de las necesidades):

- IGM-Exposición OWASP (Top 10)
Variables: P3.2, P3.3, P3.4, P3.5, P3.6.
- IGM-Madurez de Programa (SAMM)
Variables: P4.1–P4.6.
- IGM-Aseguramiento Técnico (ASVS)
Variables: P5.1–P5.6.
- IGM-Gobernanza y Cultura
Variables: P2.1–P2.5, P6.1–P6.5, P7.1–P7.5, P8.1–P8.4, P9.1–P9.3.

IGM-Exposición OWASP (Top 10)

Variables: P3.2, P3.3, P3.4, P3.5, P3.6.

IGM-Madurez de Programa (SAMM)

Variables: P4.1–P4.6.

IGM-Aseguramiento Técnico (ASVS)

Variables: P5.1–P5.6.

IGM-Gobernanza y Cultura

Variables: P2.1–P2.5, P6.1–P6.5, P7.1–P7.5, P8.1–P8.4, P9.1–P9.3.

5.3. Normalización y ponderación

15. Normalización:

Cada pregunta se transforma en una escala 0–100 siguiendo reglas predefinidas; por ejemplo:

16. Peor situación posible – 0.

17. Mejor situación posible – 100.

18.

Valores intermedios equiespaciados.

19.

Ponderación interna:

Dentro de cada subíndice, se puede optar por:

20. Ponderación igualitaria de todas las preguntas.

21.

Ponderaciones diferenciadas basadas en consenso experto (por ejemplo, más peso a MTTR o a participación de la alta dirección).

22.

Ponderación global:

El IGM puede ser:

23.

Una media simple de los cuatro subíndices (25 % cada uno), o

24. Una media ponderada (por ejemplo, más peso a Gobernanza y Cultura en sectores altamente regulados).

Valores intermedios equiespaciados.

Ponderación interna:

Dentro de cada subíndice, se puede optar por:

Ponderaciones diferenciadas basadas en consenso experto (por ejemplo, más peso a MTTR o a participación de la alta dirección).

Ponderación global:

El IGM puede ser:

Una media simple de los cuatro subíndices (25 % cada uno), o

La plantilla Excel incluirá los coeficientes de ponderación para permitir la personalización.

6. ROI de seguridad (enfoque conceptual)

La plantilla incluye una estimación del **ROI de ciberseguridad** basada en dos componentes:

25.

Reducción de riesgo estimada

A partir de indicadores antes/después (por ejemplo, descenso de vulnerabilidades críticas, mejora de MTTR, reducción de incidentes graves), se estima el valor económico del riesgo evitado.

26.

Costes de inversión y operación

Se consolidan costes de proyectos, personal, herramientas y servicios relacionados con las mejoras de seguridad implementadas.

Reducción de riesgo estimada

A partir de indicadores antes/después (por ejemplo, descenso de vulnerabilidades críticas, mejora de MTTR, reducción de incidentes graves), se estima el valor económico del riesgo evitado.

Costes de inversión y operación

Se consolidan costes de proyectos, personal, herramientas y servicios relacionados con las mejoras de seguridad implementadas.

La fórmula conceptual es:

$$\text{ROI aproximado} = (\text{Riesgo evitado} - \text{Costes de seguridad}) / \text{Costes de seguridad}$$

Dado que la estimación de “riesgo evitado” implica supuestos y modelos propios, la plantilla proporciona campos para que cada organización introduzca sus parámetros (por ejemplo, coste promedio de incidente, probabilidad estimada de ocurrencia, etc.).

7. Plan de implementación de la encuesta

7.1. Fases sugeridas

27.

Diseño y adaptación sectorial

Ajustar terminología, ejemplos y bloques a las peculiaridades de cada sector (salud, energía, banca, administración pública, etc.).

28.

Piloto controlado

Ejecutar la encuesta en un grupo reducido de organizaciones voluntarias para depurar preguntas y tiempos de respuesta.

29.

Despliegue nacional

Ampliar a la población objetivo con acompañamiento (sesiones informativas, soporte técnico y metodológico).

30.

Análisis y retroalimentación

Generar informes sectoriales y generales, compartir resultados agregados y revisar las preguntas para futuras ediciones.

Diseño y adaptación sectorial

Ajustar terminología, ejemplos y bloques a las peculiaridades de cada sector (salud, energía, banca, administración pública, etc.).

Piloto controlado

Ejecutar la encuesta en un grupo reducido de organizaciones voluntarias para depurar preguntas y tiempos de respuesta.

Despliegue nacional

Ampliar a la población objetivo con acompañamiento (sesiones informativas, soporte técnico y metodológico).

Análisis y retroalimentación

Generar informes sectoriales y generales, compartir resultados agregados y revisar las preguntas para futuras ediciones.

7.2. Canales de distribución

- Formularios online (preferentemente seguros y alojados en Europa).
- Versiones descargables en formato PDF/Markdown para aquellas organizaciones que prefieran respuesta offline, con posterior carga manual.

7.3. Duración estimada

Para una organización con información razonablemente estructurada, el tiempo estimado para completar la encuesta oscila entre **45 y 90 minutos**, dependiendo del grado de detalle aportado en comentarios.

8. Consideraciones éticas y de confidencialidad

- Los datos individuales de las organizaciones deben tratarse con confidencialidad estricta y almacenarse de forma segura.
- Los resultados publicados deben ser siempre agregados (por sector, tamaño, tipo de entidad) salvo acuerdo explícito para casos particulares.
- Se recomienda ofrecer a las organizaciones participantes un informe de retorno que compare su posición con el promedio sectorial y global.

9. Uso recomendado de los resultados

A nivel **organizativo**:

- Identificar brechas específicas (por ejemplo, baja madurez SAMM en Gobernanza, usos limitados de ASVS, falta de métricas de riesgo).
- Priorizar inversiones en función de impacto y viabilidad.
- Comunicar de forma clara a la alta dirección la posición real frente a marcos reconocidos.

A nivel **nacional o sectorial**:

- Establecer una línea base (baseline) de madurez y exposición.
- Medir la evolución en el tiempo (series temporales del IGM y subíndices).
- Alimentar la elaboración de políticas, guías y programas de apoyo.

10. Recomendaciones finales

- No convertir la encuesta en un mero ejercicio de “compliance”; su valor reside en la honestidad de las respuestas.
- Acompañar los resultados con sesiones cualitativas (talleres, grupos de trabajo) para interpretar matices que los números no capturan.
- Mantener el cuestionario vivo: revisar anualmente a la luz de nuevas versiones de OWASP, cambios normativos y lecciones aprendidas.

Esta guía no pretende ser un dogma, sino un punto de partida razonablemente sólido para medir con cierta gracia, pero sin frivolidad, cómo de preparados estamos frente a un mundo digital que no perdona la ingenuidad.